

Segurança Computacional (Katz & Lindell cap. 3)

Jeroen van de Graff (anotações Arthur)

Roteiro — Computational Security

- RSA
- Definição baseada em **vantagem** (advantage-based) — §2.6 $\Rightarrow$ §3.8
- **Semantic Security** — definição por *distinguisher* / indistinguibilidade (§3.14), *next-bit*
- **Pseudo Random Generators** (PRG)
- Encriptação a partir de PRG (§3.16)
- **Chosen Plaintext Attack** — **CPA** (§3.21)

Semantic Security (§3.10–3.12) — não está no livro.

RSA

1. Escolher p, q primos de tamanho 1024 bits.
2. Computar $n = p \cdot q$ — (GenKey). Note $\varphi(n) = |\mathbb{Z}_n^*|$.
3. Computar $\varphi = \varphi(n) = (p-1)(q-1)$.
4. Escolher $e = 65537$ e computar d tal que

$$ed \equiv 1 \pmod{\varphi}$$

Operações:

$$\text{Enc}_{(n,e)}(m) = m^e \bmod n \quad \text{Dec}_{(n,d)}(c) = c^d \bmod n$$

Corretude

$$\text{Dec}(\text{Enc}(m)) \equiv \text{Dec}(m^e \bmod n) \equiv (m^e)^d$$

Como $ed \equiv 1 \pmod{\varphi} \iff ed = 1 + k\varphi$:

$$(m^e)^d \equiv m^{1+k\varphi} \equiv m \cdot (m^\varphi)^k \equiv m \cdot 1^k \equiv m$$

logo $\text{Dec} \rightarrow m$. (usa Euler: $m^{\varphi(n)} \equiv 1 \pmod n$, válido para $\gcd(m, n) = 1$; para os demais m a igualdade ainda vale, via CRT em $\text{mod } p$ e $\text{mod } q$.)

Goldwasser–Micali (GM) cryptosystem

Mensagens: $m_0 = \text{'YES'}$, $m_1 = \text{'NO'}$. A encriptação usa **randomness**, então cada mensagem tem *muitos* cifrados possíveis:

$$\text{Enc}(\text{'YES'}) \rightarrow \{c_1, c_2, \dots\} \quad \text{Enc}(\text{'NO'}) \rightarrow \{c'_1, c'_2, \dots\}$$

Os dois conjuntos são **disjuntos** (senão Dec não funcionaria); o ponto é que são computacionalmente indistinguíveis. É isso que permite ser CPA-seguro, coisa que RSA “livro-texto” (determinístico) não é.

Propriedade homomórfica:

$$\text{Enc}(m_1) \cdot \text{Enc}(m_2) = \text{Enc}(m_1 \oplus m_2)$$

(em GM a mensagem é um **bit** e o produto dos cifrados decripta para o XOR; a versão com $m_1 \cdot m_2$ é a do RSA, que é multiplicativo.)

Resíduos quadráticos

Módulo primo p . y é raiz quadrada de $x \pmod p$ se $y^2 \equiv x \pmod p$. Em $\mathbb{Z}_p^*$ (que tem $p-1$ elementos):

- $\frac{p-1}{2}$ são resíduos quadráticos (têm raiz) — escrevemos $\left(\frac{x}{p}\right) = +1$
- $\frac{p-1}{2}$ não são — $\left(\frac{x}{p}\right) = -1$

Aqui decidir é **fácil**: critério de Euler, $x^{(p-1)/2} \pmod p$.

Módulo composto $N = p \cdot q$. Cada $x \in \mathbb{Z}_N^*$ tem um status mod p e um status mod q (CRT), dando 4 células de tamanho $\frac{(p-1)(q-1)}{4}$ cada. O símbolo de **Jacobi** é o produto dos dois: $\left(\frac{x}{N}\right) = \left(\frac{x}{p}\right) \left(\frac{x}{q}\right)$ — e é computável em tempo polinomial **sem** fatorar N .

		mod q		
		QR mod q	NQR mod q	
mod p	QR mod p	Jacobi +1 é QR mod N	Jacobi -1	hachurado = Jacobi +1 (J_N^{+1})
	NQR mod p	Jacobi -1	Jacobi +1 não é QR mod N	

O Jacobi separa hachurado de não-hachurado, mas **não** distingue as duas células da diagonal. Essa é a **Quadratic Residuosity Assumption (QRA)**: dado x com $(\frac{x}{N}) = +1$, decidir se x é QR mod N é difícil sem conhecer p, q .

É daí que sai o GM: $\text{Enc}(0) = r^2$, $\text{Enc}(1) = x_0 \cdot r^2$, com r aleatório e x_0 um pseudoquadrado fixo (célula de baixo). Os dois cifrados vivem na diagonal hachurada — distingui-los é o problema QRA.

Concrete approach

Um esquema é (t, ε) -**seguro** se qualquer adversário rodando por tempo t consegue quebrá-lo com probabilidade $\leq \varepsilon$.

$$2^{64} \longrightarrow 2^{128}$$

Asymptotic approach

Um esquema é seguro se todo adversário **PPT** (Probabilistic Polynomial Time) tem sucesso com probabilidade **desprezível** (negligible):

$$f(n) < \frac{1}{\text{poly}(n)}$$

(informalmente; a versão precisa — *para todo* polinômio, *para todo* n grande — está logo abaixo.)

Propriedades de funções desprezíveis:

- $\text{negl}_1(n) + \text{negl}_2(n)$ também é desprezível
- $p(n) \cdot \text{negl}(n) < \text{negl}'(n)$ (polinômio vezes desprezível ainda é desprezível)

Definição. Um esquema é seguro se, para todo adversário PPT $\mathcal{A}$ e todo polinômio p , existe N tal que para todo $n > N$:

$$\Pr[\text{success}] < \frac{1}{p(n)}$$

Esquema de encriptação de chave privada

Gen : entrada 1^n ; saída: chave aleatória k

Enc : $c \leftarrow \text{Enc}_k(m)$

Dec : $m' := \text{Dec}_k(c)$

EAV-security (eavesdrop)

- adversário passivo, **uma** única observação
- Adv é PPT

$$\begin{array}{ccc} \mathcal{A} & \xrightarrow{m_0, m_1} & \text{ORACLE} \\ & \xleftarrow{c = \text{Enc}_k(m_b)} & b \xleftarrow{R} \{0, 1\} \end{array}$$

O adversário **produz um palpite** b' e **vence se** $b = b'$.

Definição. $\Pi = (\text{Gen}, \text{Enc}, \text{Dec})$ tem *indistinguishable encryptions* na presença de um eavesdropper se para todo PPT $\mathcal{A}$ existe negl tal que

$$\Pr[\text{PrivK}_{\mathcal{A}, \Pi}^{\text{eav}}(n) = \text{SUCCESS}] \leq \frac{1}{2} + \text{negl}(n) \approx \frac{1}{2}$$

Semantic security — versão com predicado

Seja B um predicado sobre a mensagem, p.ex.

$$B(m_0) = 0, \quad B(m_1) = 1$$

Exige-se

$$\Pr[B(m) = 1 \mid m = m_0] \approx \Pr[B(m) = 1 \mid m = m_1]$$

Se as probabilidades são iguais, é o mesmo que um palpite aleatório — o adversário não sabe qual mensagem é qual, não ganha nada bisbilhotando.

Para uma mensagem por blocos $m = m_1 m_2 m_3 \dots m_k$, com $c = \text{Enc}_k(m)$, pergunta-se por qualquer função $f(m) \rightarrow \{0, 1\}$.

Next-bit predictability

Dado $r_1, \dots, r_n$, prever $r_{n+1} = 0$ ou 1 :

$$\Pr[\text{SUCCESS}] \leq \frac{1}{2} + \text{negl}$$

Definição — Pseudo Random (Bit/Number) Generator, PRG G

$$s \mapsto G(s), \quad |s| = n, \quad |G(s)| = \ell(n)$$

Para todo *distinguisher* PPT D existe $\text{negl}(n)$ tal que, com $r \xleftarrow{R} \{0, 1\}^{\ell(n)}$:

$$\left| \Pr[D(G(s)) = 1] - \Pr[D(r) = 1] \right| < \text{negl}(n)$$

Expansão: $n \rightarrow 2n$

$G : \{0, 1\}^n \rightarrow \{0, 1\}^{2n}$ — dobra o tamanho? A imagem é minúscula:

Exemplo $n = 5$:

$$2^5 = 32 \text{ valores possíveis} \subseteq \{0, 1\}^{10} = 1024 \text{ valores}$$

- 32 valores com probabilidade $\frac{1}{32}$
- 992 valores com probabilidade 0
- uniforme daria $p = \frac{1}{1024}$

Seed = 5, expande para 10: gera saída de tamanho 10, mas só cai nos 32 iniciais.

De forma geral:

$$k \in \{0, 1\}^n \Rightarrow \text{Im}(G) \subseteq \{0, 1\}^{2n}, \quad |\text{Im}(G)| = 2^n$$

$$\frac{2^n}{2^{2n}} = \frac{1}{2^n}$$

Probabilidade de **cada string** $w \in \{0, 1\}^{2n}$ individual:

	Uniform	PRG
$w \in \text{Im}(G)$	$1/2^{2n}$	$1/2^n$
$w \notin \text{Im}(G)$	$1/2^{2n}$	0

(confere com o exemplo $n = 5$: uniforme dá $1/1024$ a cada string; o PRG dá $1/32$ às 32 strings da imagem e 0 às outras 992.)

A massa total que a uniforme coloca dentro de $\text{Im}(G)$ é $\frac{2^n}{2^{2n}} = \frac{1}{2^n}$ — desprezível. Logo **existe** um distinguisher trivial (“ w está em $\text{Im}(G)$?”) com vantagem ≈ 1 , mas ele **não é PPT**: testar isso exige percorrer as 2^n seeds. Por isso a definição de PRG quantifica só sobre distinguishers polinomiais.

Dois tipos de definição

1. Duas distribuições indistinguíveis

$$|\Pr[D(\text{Enc}(m_0)) = 1] - \Pr[D(\text{Enc}(m_1)) = 1]| < \frac{1}{\text{poly}}$$

$$|\underbrace{\Pr[D(G(k)) = 1]}_{\text{PRG}} - \underbrace{\Pr[D(w) = 1]}_{\text{Uniform}}| < \frac{1}{\text{poly}}$$

2. Advantage-based

- envolve um **jogo**
- o adversário tem que adivinhar $b' \in \{0, 1\}$
- o adversário vence com $\Pr[\] \leq \frac{1}{2} + \frac{1}{\text{poly}}$

Encriptação a partir de um PRG

$$\Pi : \begin{cases} \text{Enc}_k(m) = m \oplus G(k) \\ \text{Dec}_k(c) = c \oplus G(k) \end{cases}$$

com $n \rightarrow \ell(n)$, isto é $|k| = n$ e $|m| = \ell(n)$ — a chave é **menor** que a mensagem (ao contrário do OTP). Isso **não** contradiz o Teorema 2.11 da aula passada ($|\mathcal{K}| \geq |\mathcal{M}|$): aquele teorema é sobre sigilo *perfeito*; aqui o esquema é apenas computacionalmente seguro.

Teorema (redução). Um ataque contra Π (protocolo) pode ser transformado num ataque contra o PRG G .

Prova (esboço) — construir o distinguisher $D(w)$

1. obter m_0, m_1 do adversário $\mathcal{A}$
2. escolher um bit b , definir $c = w \oplus m_b$ e devolver c a $\mathcal{A}$
3. $\mathcal{A}$ devolve b' ; D produz 1 sse $b = b'$

$$\begin{array}{ccc} \mathcal{A} & \xrightarrow{m_0, m_1} & b \in \{0, 1\} \\ \text{guess } b' & \xleftarrow{\text{Enc}(m_b)} & \end{array} \quad \begin{cases} b = b' \Rightarrow \text{SUCCESS} \\ b \neq b' \Rightarrow \text{FAIL} \end{cases}$$

Caso 1 — w **uniforme**. Então $c = w \oplus m_b$ é um one-time pad perfeito:

$$\Pr[D(w) = 1] = \Pr[\text{PrivK}_{\mathcal{A}, \Pi}^{\text{eav}}(n) = 1] = \frac{1}{2}$$

Caso 2 — $w = G(k)$. Então o jogo é exatamente Π :

$$\Pr[D(G(k)) = 1] = \Pr[\text{PrivK}_{\mathcal{A}, \Pi}^{\text{eav}}(n) = 1]$$

Pela definição de PRG a diferença é desprezível, logo

$$\left| \Pr[\text{PrivK}_{\mathcal{A}, \Pi}^{\text{eav}}(n) = 1] - \frac{1}{2} \right| < \frac{1}{\text{poly}}$$

Experimentos: EAV vs CPA

EAV-experiment

$$\begin{array}{ccc} \text{Adv escolhe } m_0, m_1 & \xrightarrow{\quad} & \text{ORACLE, } b \in \{0, 1\} \\ \text{guess } b' & \xleftarrow{\text{Enc}(m_b)} & \end{array}$$

Se $b = b'$ então **Adv vence**.

CPA-experiment (Chosen Plaintext Attack)

O adversário tem acesso a um oráculo de encriptação **livremente**, antes do desafio:

$$\begin{array}{ccc} \text{Adv} & \xrightarrow{m} & \text{ORACLE : } c = \text{Enc}_k(m) \text{ \{livre\}} \\ & \xleftarrow{c} & \\ \text{então Adv escolhe } m_0, m_1 & \xrightarrow{\quad} & b \in \{0, 1\} \\ \text{guess } b' & \xleftarrow{\quad} & \end{array}$$

Se $b = b'$ então **vence**.

Consequência: encriptação CPA-segura **precisa ser randomizada** — determinística perde na hora, pois o adversário pede $\text{Enc}(m_0)$ ao oráculo e compara.